

The role of the CISO

You Get The CISO You Deserve

10/9/26

Prof. dr. mult. Yuri Bobbert

Antwerp Management School

Introduction

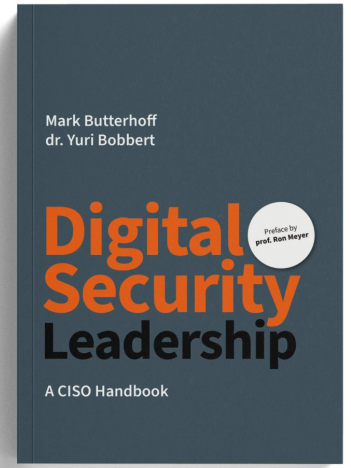
Prof.dr.mult Yuri Bobbert

- Professor and Academic Director Antwerp Management School (AMS)
- CEO & Co-founder Anove.ai, founder of Explain-ai.com
- Former global head of Risk, Security & Compliance (CSO/CRO) NN Group & UWV, ON2IT Cybersecurity (EU and US)









By the end of this session, you should be able to:

- Explain the main topics and responsibilities of the CISO.
- Understand how cybersecurity is managed and governed in any organisation.
- Explain the main stakeholders involved in cybersecurity.
- Understand what matters most in a specific organisational environment.
- Explain the different types of CISOs.
- Understand how cyber roles and capabilities evolve over time.

Leading Digital Security, the role of the CISO

Leading

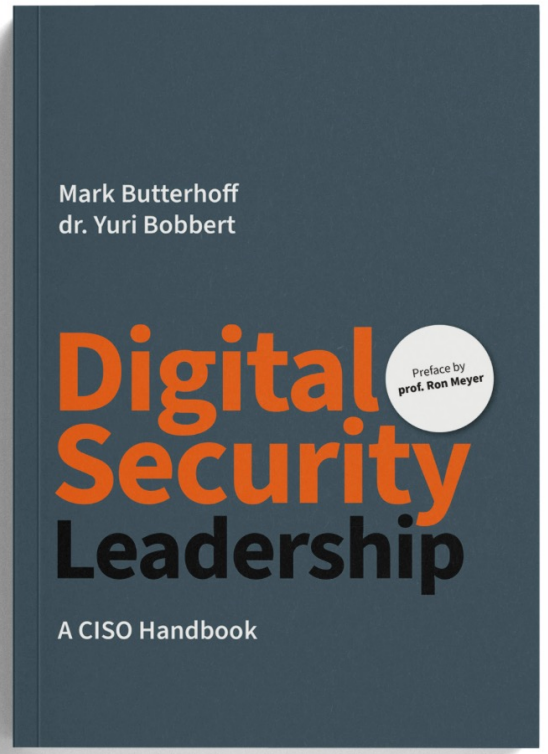
Strategizing

Changing

Governing

Funding

Trending



What is the primary objective and responsibility of the Chief Information Security Officer?

How is security governed and managed in any organisation?

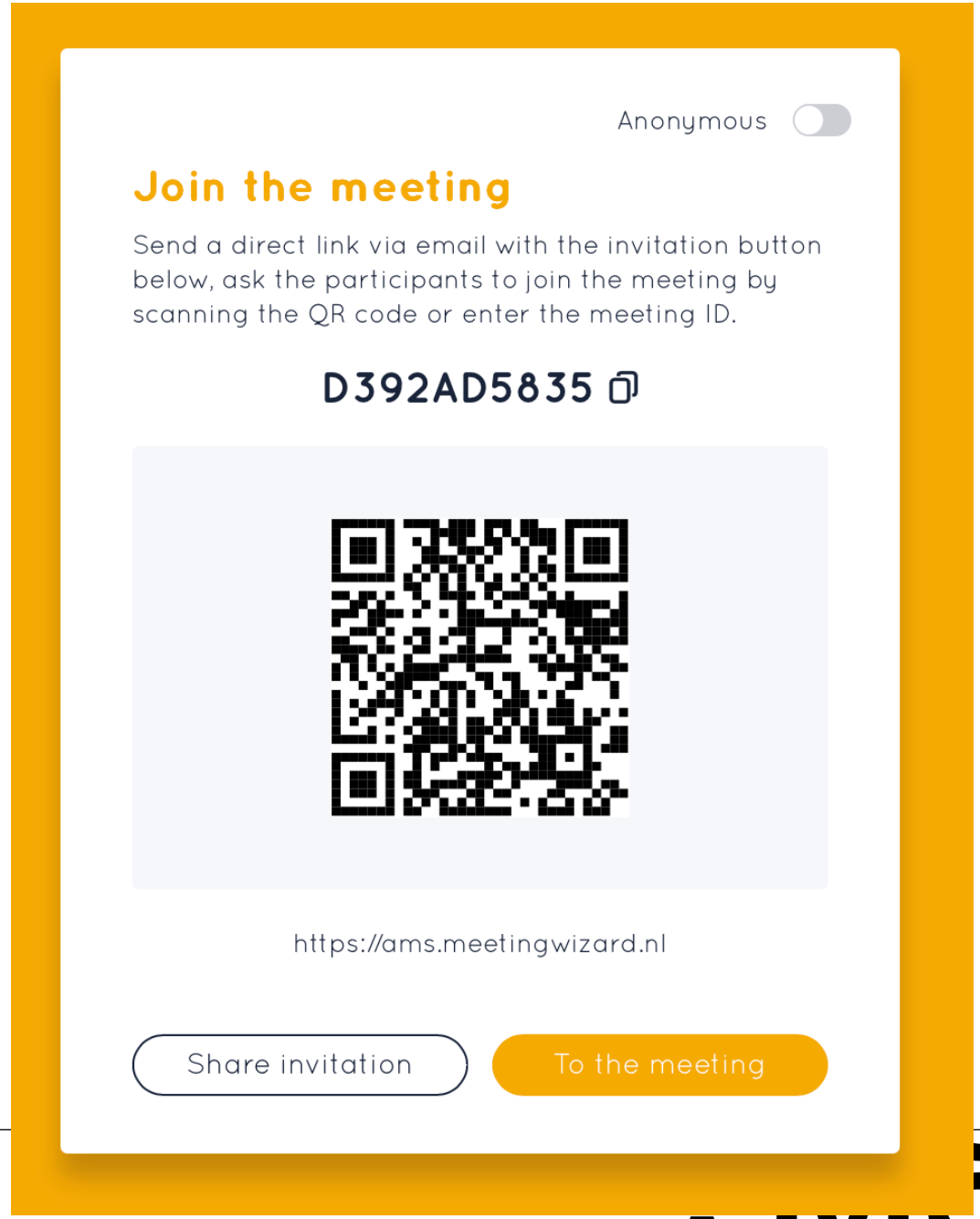
Which archetypes of organisations and CISOs can be distinguished, and which should you know?

What matters most for a CISO?

How do future roles emerge and shape the field?

What is your own position and future perspective?

How do we reflect on what we have learned in this session?



Who wants to become a CISO?



48% of CISOs said the levels of stress they are under has impacted their mental health



35% of CISOs reported that their stress had impacted their physical health



90% of CISOs said they'd take a pay cut if it improved their work-life balance

What is the CISO primarily responsible for?

A. Configuring firewalls

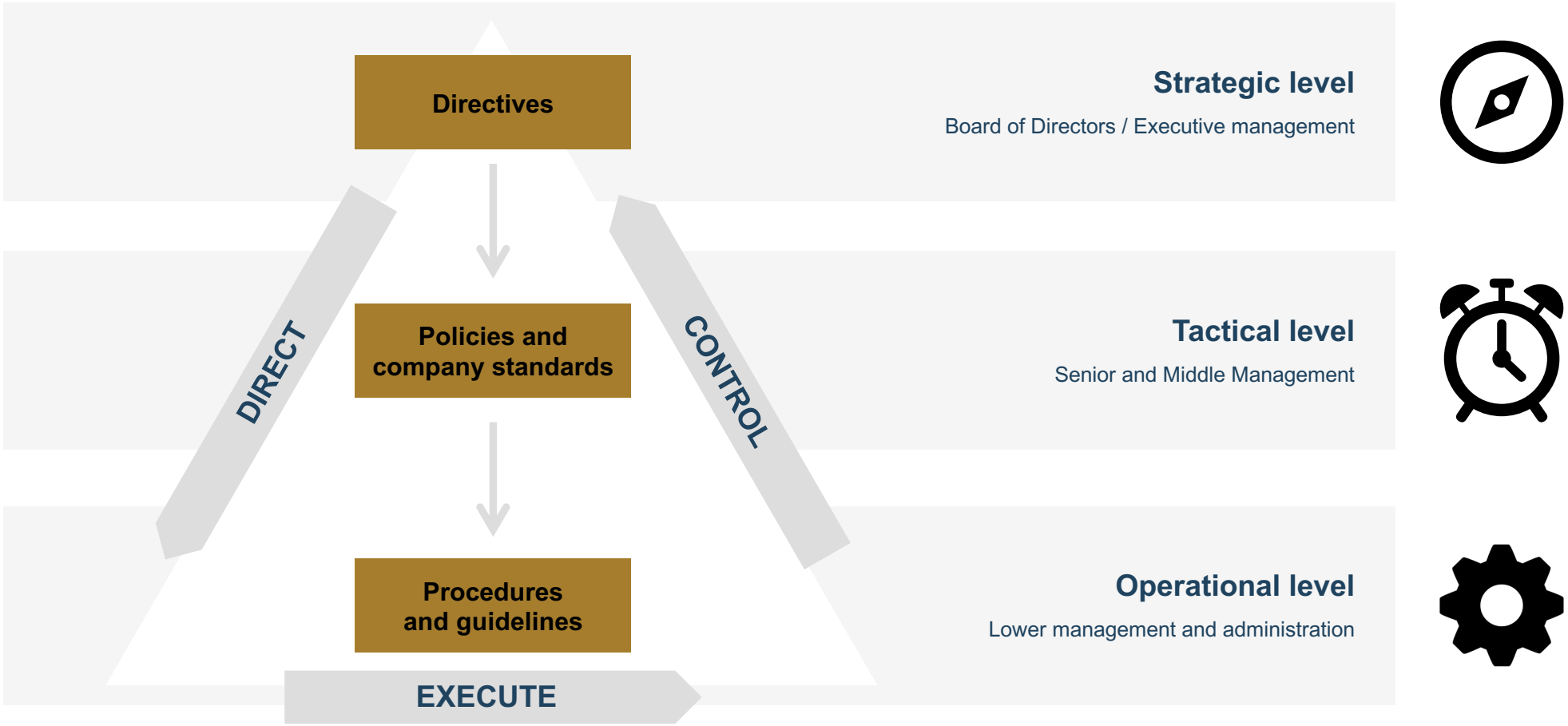
B. Managing cyber risk and security strategy

C. Writing code securely

D. Approving all software purchases

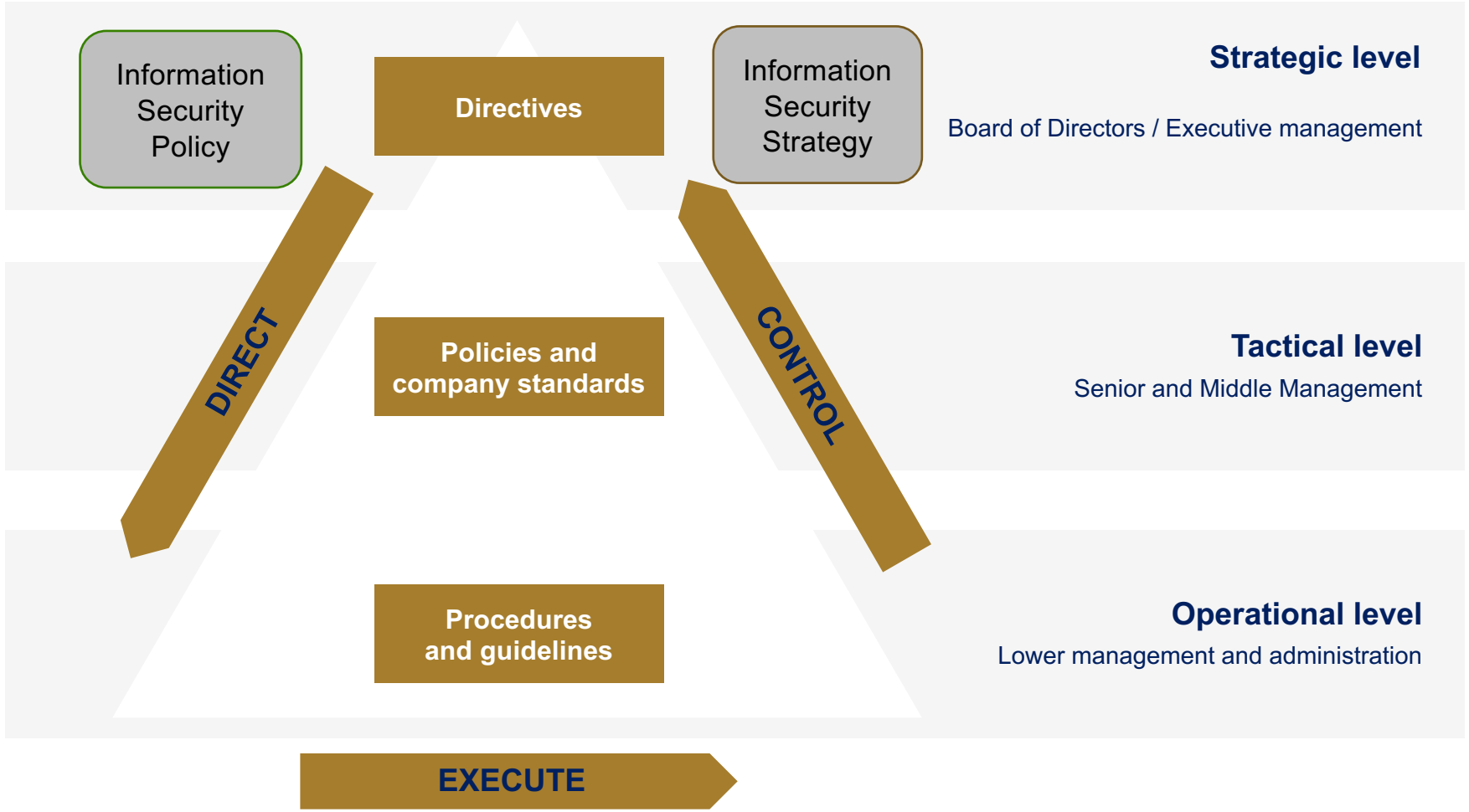
Direct - monitor - control-cycle
Theoretical lens for assessing the multiple layers

Type of Document	Level	Objective	Scope
1. Corporate Policy	Strategic	Set high-level expectations	Whole organisation
2. Standard	Tactical	Set quantifiable requirements or baseline	Protect Surface
3. Technical Procedure	Operational	Describes execution and implementation	Protect Surface



Source:
Von Solms & Von Solms (2006) Information Security Governance
Bobbert, (2018) Improving the Maturity of Business Information Security; On the Design & Engineering of a Security Artefact

Without proper digital risk, security and strategic guidance boards cannot take responsibility.



Source: Bobbert (2018) Improving the Maturity of Business Information Security

Reading Material: Bobbert (2020) Which 4 CISO Architypes do you deserve?

Without proper digital risk, security information, nobody can take accountability



Source: Bobbert, (2018) Improving the Maturity of Business Information Security; On the Design & Engineering of a Security Artefact

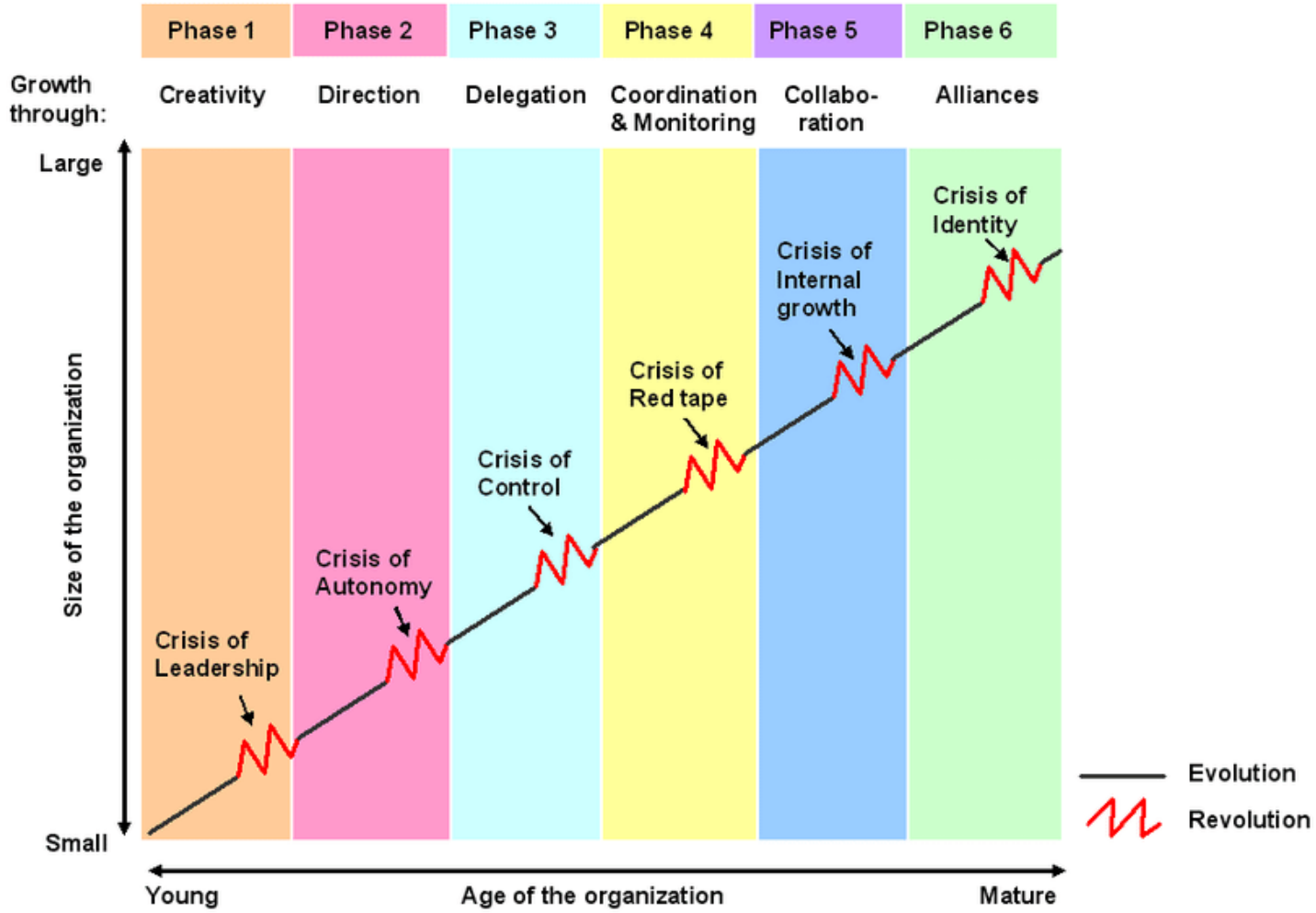
How we view firms, collaborate and gain assurance…

Type of Document	Level	Objective	Scope
1. Corporate Policy	Strategic	Set high-level expectations	Whole organisation
2. Standard	Tactical	Set quantifiable requirements or baseline	Protect Surface
3. Technical Procedure	Operational	Describes execution and implementation	Protect Surface



Source: Bobbert, (2018) Improving the Maturity of Business Information Security; On the Design & Engineering of a Security Artefact

What type of organisations do you know?



Organisation Archetypes

Dimension	Archetype
Firm-life-cycle / Growth momentum	*Startup*
	Scale-up
	Mature / Incumbent
	Turnaround / Distress
	Consolidator
Growth mode / Deal logic	*M&A Roll-up*
	Platform / Ecosystem Orchestrator
Geographic footprint	*Domestic Champion*
	Global Multinational
Ownership / Governance	*Family-Owned and Controlled*
	Publicly Listed (PLC)
	Private-Equity-Backed
	State-Owned Enterprise (SOE)
	Co-operative / Mutual
	Non-Profit / NGO
Structural design	*Centralised Functional*
	Divisional / Decentralised
	Matrix / Networked

Organisation Archetypes

Dimension	Archetype	Essence
Firm-life-cycle / Growth momentum	*Startup*	Pre-revenue or early-revenue venture searching for product–market fit.
	Scale-up	Proven model, now racing for share, funding, and talent.
	Mature / Incumbent	Stable cash-cow lines, incremental innovation.
	Turnaround / Distress	Shrinking core, liquidity crunch.
	Consolidator	Grows primarily by absorbing weaker rivals in a maturing sector.
Growth mode / Deal logic	*M&A Roll-up*	Serial acquirer knitting a fragmented market.
	Platform / Ecosystem Orchestrator	Enables multisided transactions (e.g., marketplaces, app stores)
Geographic footprint	*Domestic Champion*	>80 % revenue in one country/region.
	Global Multinational	Distributed assets, multi-currency revenue.
Ownership / Governance	*Family-Owned and Controlled*	Majority voting and often management held by founding family.
	Publicly Listed (PLC)	Shares traded on stock exchange, quarterly scrutiny.
	Private-Equity-Backed	Leveraged buy-out with 3-7 y value-creation plan.
	State-Owned Enterprise (SOE)	Owned/controlled by government, sometimes listed minority.
	Co-operative / Mutual	Owned by members or policyholders (e.g., credit unions, mutual insurers).
	Non-Profit / NGO	Mission-driven, surplus re-invested, revenue from donations/grants.
Structural design	*Centralised Functional*	Tight HQ control, functional silos.
	Divisional / Decentralised	Profit-centre business units under corporate umbrella.
	Matrix / Networked	Dual reporting lines, global process owners.

Organisation Archetypes

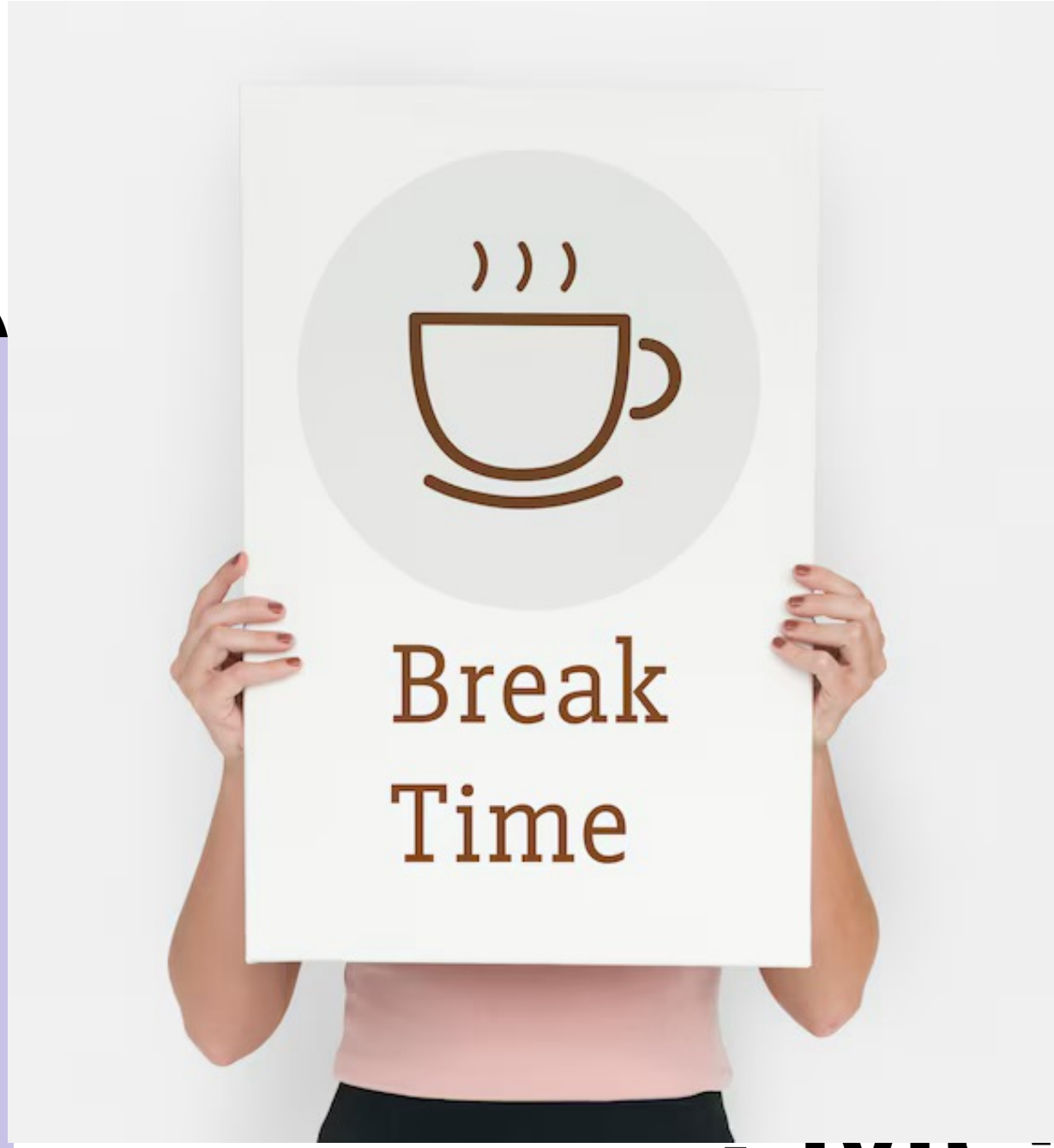
Dimension	Archetype	Essence	Typical leadership imperatives
Firm-life-cycle / Growth momentum	*Startup*	Pre-revenue or early-revenue venture searching for product–market fit.	Vision casting, speed, founder-centric, improvisation; "crisis of leadership" looming (Greiner 1).
	Scale-up	Proven model, now racing for share, funding, and talent.	Delegation, formalising processes without killing agility; culture glue.
	Mature / Incumbent	Stable cash-cow lines, incremental innovation.	Efficiency, cost discipline, portfolio pruning; risk of bureaucracy (Greiner 4).
	Turnaround / Distress	Shrinking core, liquidity crunch.	Decisive autocratic moves, cost surgery, morale rebuilding.
	Consolidator	Grows primarily by absorbing weaker rivals in a maturing sector.	Integration playbooks, synergy realisation, change fatigue management.
Growth mode / Deal logic	*M&A Roll-up*	Serial acquirer knitting a fragmented market.	Integration cadence, culture stitching, centralised value-capture teams.
	Platform / Ecosystem Orchestrator	Enables multisided transactions (e.g., marketplaces, app stores).	Network effects, partner governance, trust & safety at scale.
Geographic footprint	*Domestic Champion*	>80 % revenue in one country/region.	Deep stakeholder ties, lobbying, local optimisation.
	Global Multinational	Distributed assets, multi-currency revenue.	Balancing local autonomy & global standardisation; matrix leadership.
Ownership / Governance	*Family-Owned and Controlled*	Majority voting and often management held by founding family.	Stewardship mindset, succession planning, informal power networks.
	Publicly Listed (PLC)	Shares traded on stock exchange, quarterly scrutiny.	Investor relations, transparency, compliance, SOX-style controls.
	Private-Equity-Backed	Leveraged buy-out with 3-7 y value-creation plan.	Aggressive KPIs, exit-driven strategy, cash discipline, bolt-on deals.
	State-Owned Enterprise (SOE)	Owned/controlled by government, sometimes listed minority.	Dual mandate (public service + profit), political oversight, procurement rules.
	Co-operative / Mutual	Owned by members or policyholders (e.g., credit unions, mutual insurers).	Democratic governance, patronage dividend, consensus leadership.
	Non-Profit / NGO	Mission-driven, surplus re-invested, revenue from donations/grants.	Stakeholder-centric, legitimacy building, resource-constrained innovation.
Structural design	*Centralised Functional*	Tight HQ control, functional silos.	Directional leadership, process discipline, risk of autonomy crisis (Greiner 2).
	Divisional / Decentralised	Profit-centre business units under corporate umbrella.	Delegation, strategic control systems, risk of "fiefdoms" (Greiner 3).
	Matrix / Networked	Dual reporting lines, global process owners.	Coordination skills, influence without authority, potential "red-tape" crisis (Greiner 4).

Growth Stages

#	Phase of Growth (dominant way the firm expands)	Typical Organisation Features	Crisis that ends the phase	Why that crisis happens
1	**Creativity** – growth through product/market innovation driven by founders	Informal communication, long hours, rapid pivots	**Crisis of Leadership**	Size outgrows the founders' ability to manage everything personally
2	**Direction** – growth through clear functional structure and professional managers	Budgets, job descriptions, functional heads	**Crisis of Autonomy**	Middle managers chafe under tight top-down control and slow approval loops
3	**Delegation** – growth through decentralised profit-centres and empowered business units	P&L responsibility pushed down; incentive pay	**Crisis of Control**	Top team fears loss of visibility; local decisions diverge from corporate goals
4	**Coordination** – growth through formal planning, corporate staff, and IT/reporting systems	Matrix structures, KPIs, long-range planning	**Crisis of Red Tape**	Procedures multiply, slowing responsiveness and stifling initiative
5	**Collaboration** – growth through culture of cross-functional teamwork, knowledge-sharing, social controls	Self-managing teams, intrapreneurship, shared values	**Crisis of Internal Growth (or 'Growth' crisis)**	Even the most collaborative culture hits limits of internal resources; fresh avenues are needed
6	**Alliances** – growth through external networks, joint ventures, M&A, ecosystems	Boundary-spanning roles, partner portals, shared platforms	**Crisis of Identity**	Blurred organisational boundaries raise "who are we?" questions for employees & partners

Short video on Greiners Growth Model

Break: Back in 15 minutes



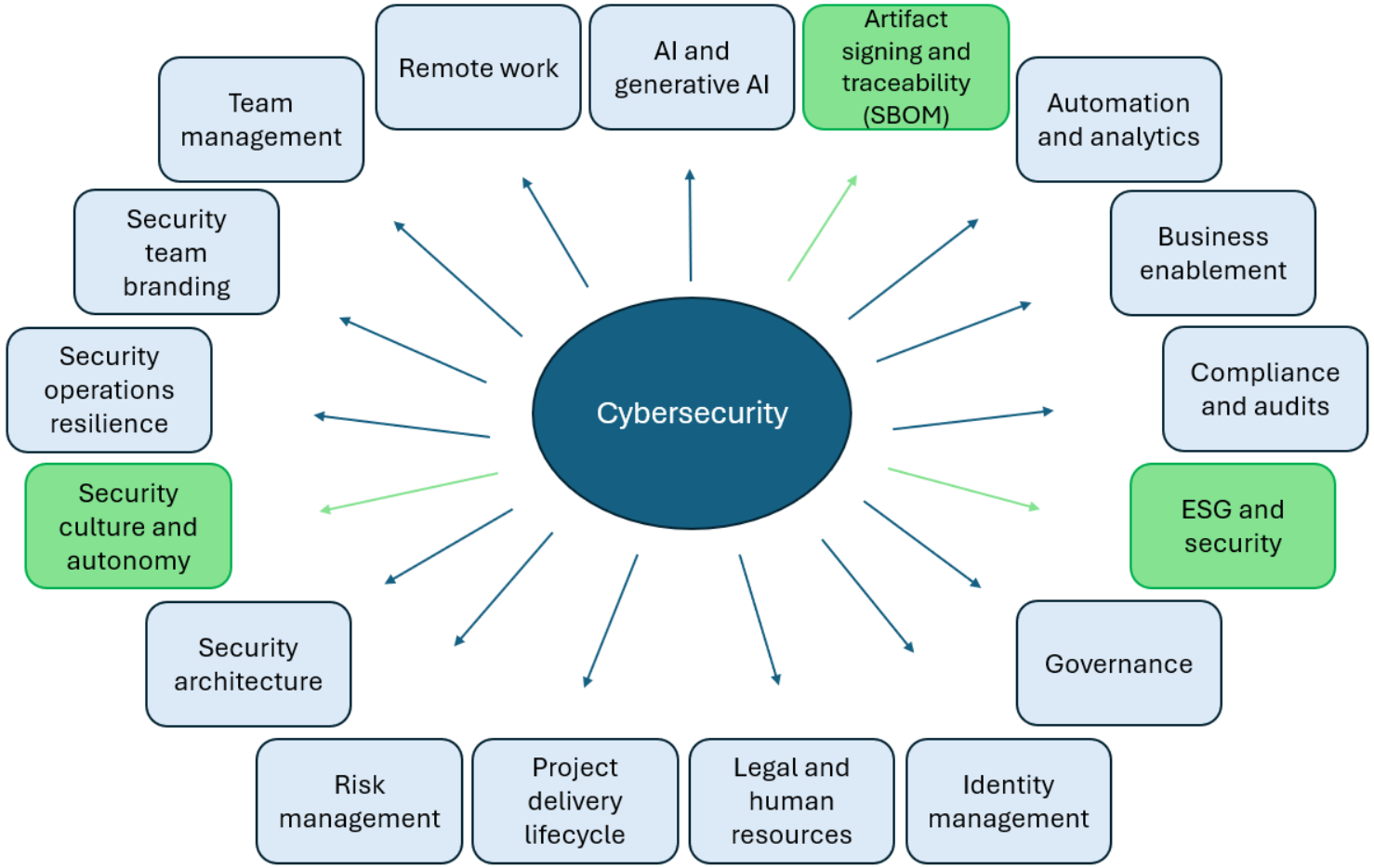
Complexity of the domain of the CISO



Source: Henry Jiang (2017)

Span of Control of the CISO in 2025

Is AI Governance a CISO Responsibility?



 Source: Magnus Jansson (2024) On defining cybersecurity and its main topics (Antwerp Management School)

Cybersecurity and its main topics

Main Topic	Brief Description
1. Governance	Establishes oversight, policies, and frameworks guiding security strategy and compliance.
2. Risk Management	Identifies threats, vulnerabilities, and potential impacts to inform risk-informed decisions.
3. Compliance and Audits	Ensures adherence to relevant laws, regulations, and standards, with regular audits for oversight.
4. Identity Management	Handles authentication, authorization, and user lifecycle to prevent unauthorized access.
5. Security Architecture	Defines technical and infrastructural safeguards (e.g., network segmentation, secure design patterns).
6. Security Operations Resilience	Maintains day-to-day security operations (e.g., threat detection, incident response, SOC functions).
7. Business Enablement	Aligns cybersecurity with strategic business goals, ensuring security adds value rather than friction.
8. AI and Generative AI	Focuses on both the security applications of AI tools and the risks they introduce.
9. Automation and Analytics	Enhances detection and response capabilities using advanced analytics and automated workflows.
10. Legal and Human Resources	Addresses legal obligations, contractual matters, investigations, and employee-related security aspects.
11. Remote Work	Covers policies, tools, and controls for secure remote access and mobile workforce management.
12. Project Delivery Lifecycle	Embeds security practices throughout development pipelines, from concept to deployment.
13. Team Management	Focuses on staffing, skills, and culture within security teams and partner stakeholders.
14. Security Team Branding	Promotes internal awareness and external credibility of the security team’s mission.
Potential New Topics	Security Culture and Autonomy, Artifact Signing and Traceability, ESG and Security

 Source: Magnus Jansson (2024) On defining cybersecurity and its main topics (Antwerp Management School)

The four archetype CISOs

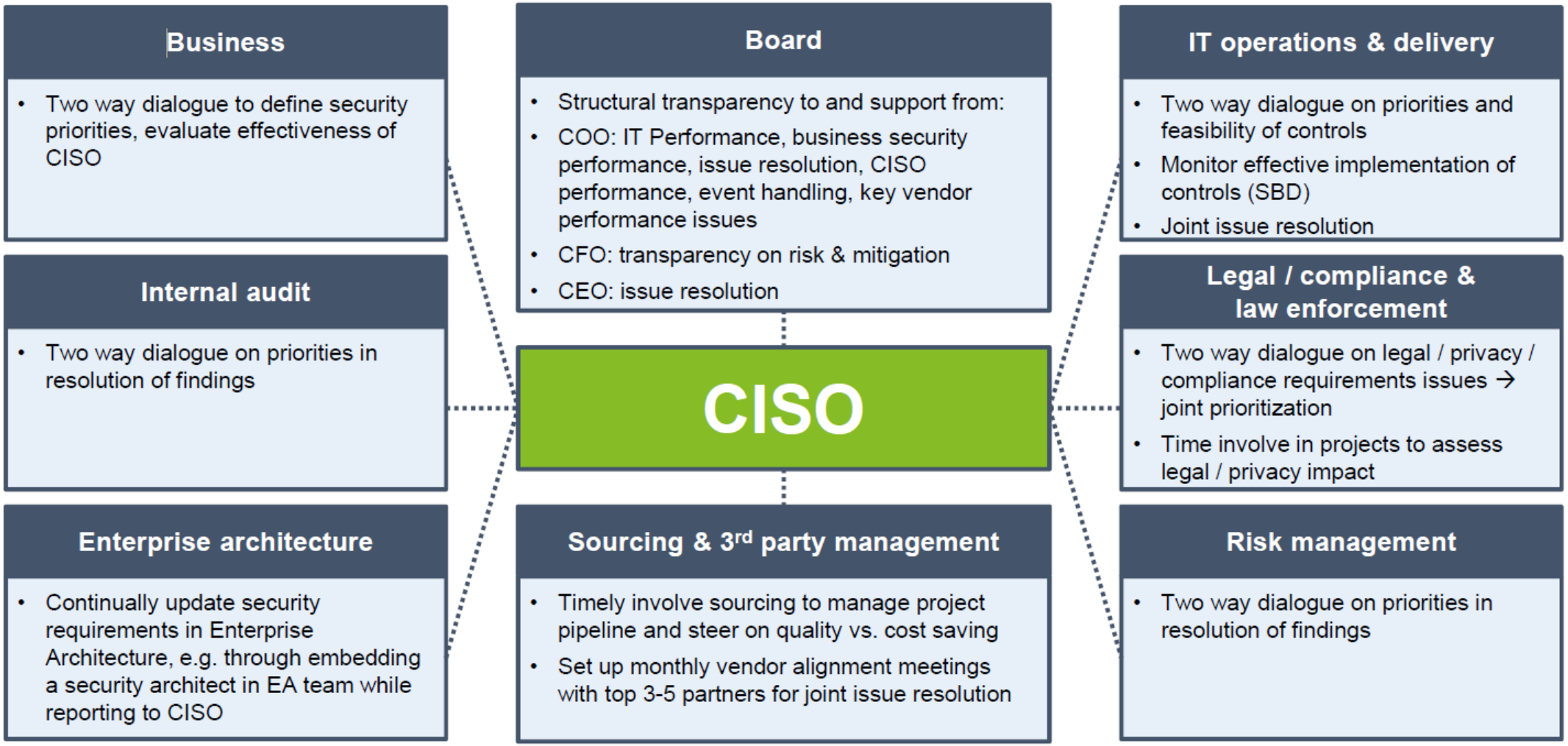
1. **(Corporate) Information Security Officer (CISO)**
2. **Chief IT security officer (CISO)**
3. **Chief Information Security Officer (CISO)**
4. **Chief Information Security Orchestrator (CISO)**

Virtual CISO is on the rise

Source: Bobbert (2020) You get the CISO you deserve

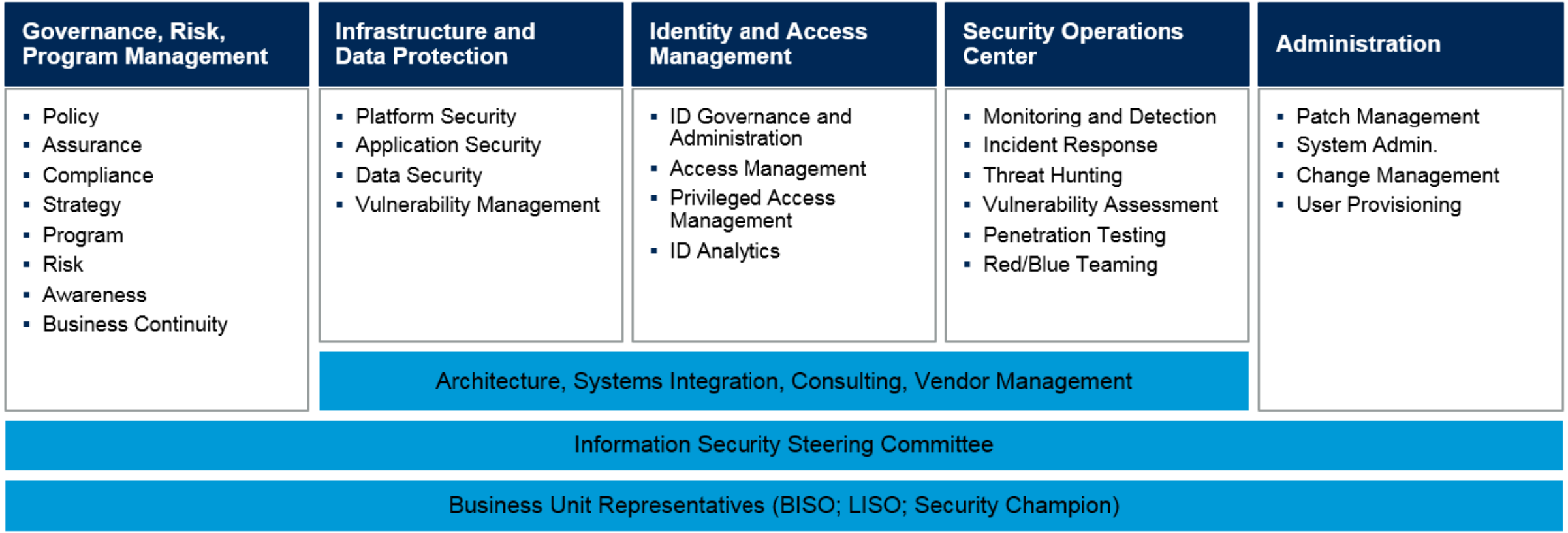
What are important stakeholders of the CISO?

Stakeholders of the CISO



 Source: Deloitte (2019) The future of cyber survey

The CISO capabilities



BISO = business information security officer; LISO = local information security officer

Rank what matters most for a CISO

technical knowledge,

leadership,

communication,

business understanding,

ethics,

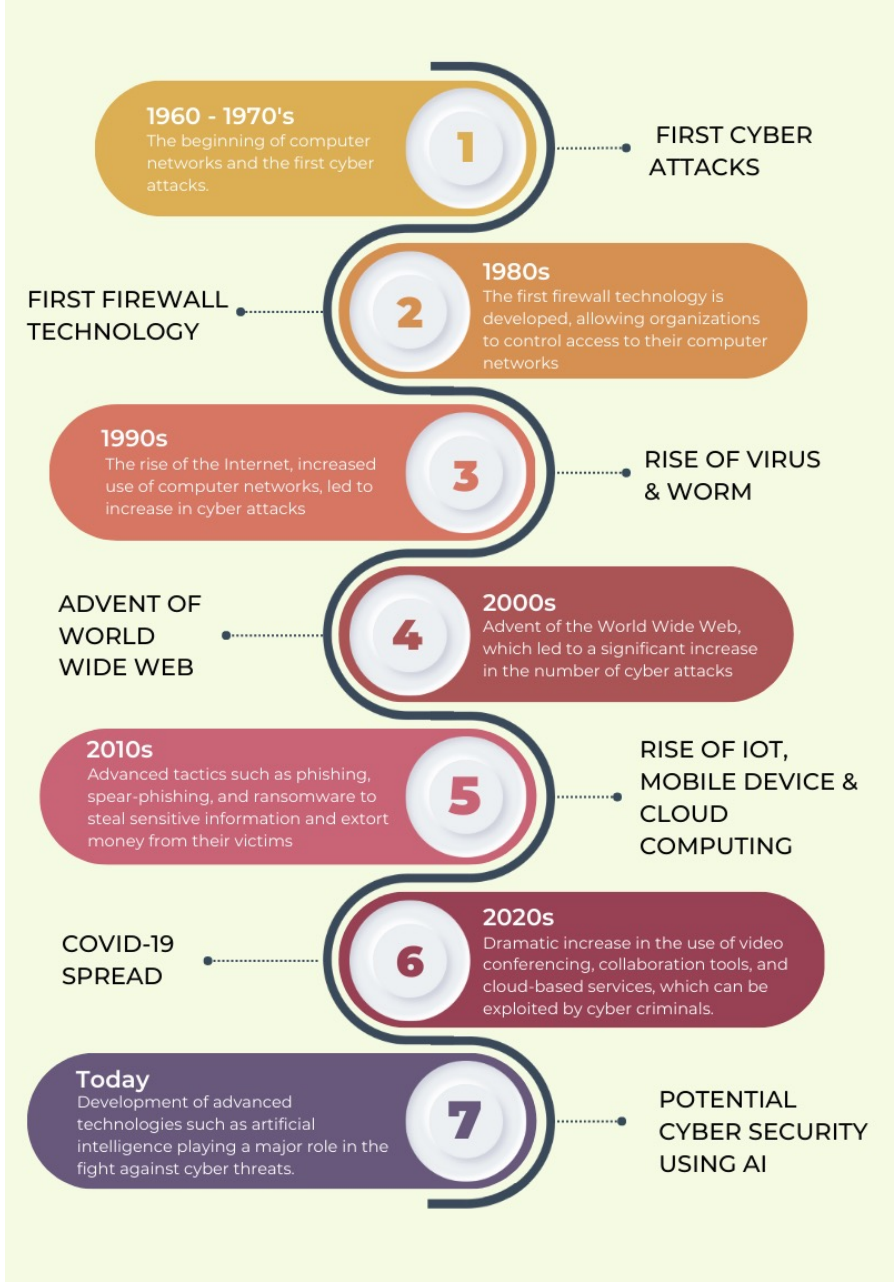
crisis handling.

Trends impacting organisations

Supporting Materials

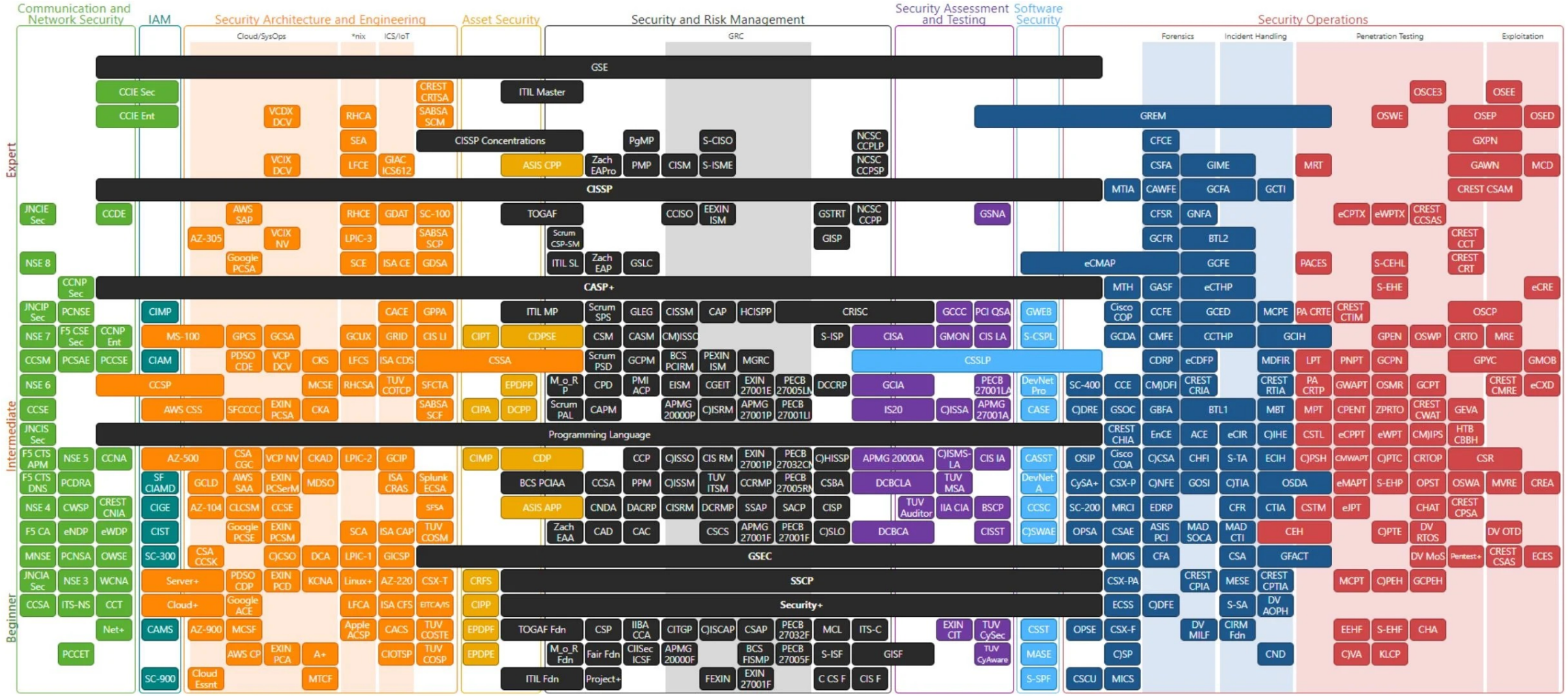
- **Sophistication and dynamics of cyber attacks**
- **Machine learning and artificial intelligence**
- **Virtual identities**
- **Data**
- **Distributed hybrid environments (legacy, cloud, OT etc)**
- **New ways of working (DevOps, Agile, Scrum)**
- **Continuous software development**
- **Regulatory and assurance (Integrated reporting)**

How requirements evolve



 Mundzir (2023) The Evolution of Cybersecurity: A Journey Through the History of Computer Security

How capabilities evolves



How cyber roles emerge

- Cyber Attack Agent,
- Cyber Calamity Forecaster,
- Machine Risk Officer
- Virtual Identity Defender,
- Data trash engineer,
- Cloud orchestration architect,
- Security vaccinator,
- Cyber talent magnet,
- AI auditor,
- Security pusher,
- Security User Experience (SUX) Designer,
- Cyber Philosopher,
- Cyberdiplomat

European e-Competence Framework (e-CF)

The European e-Competence Framework (e-CF) provides a reference of 40 competences that apply to the Information and Communication Technology (ICT) workplace. It describes the competences, skills and knowledge requirements of ICT professionals at five proficiency levels.

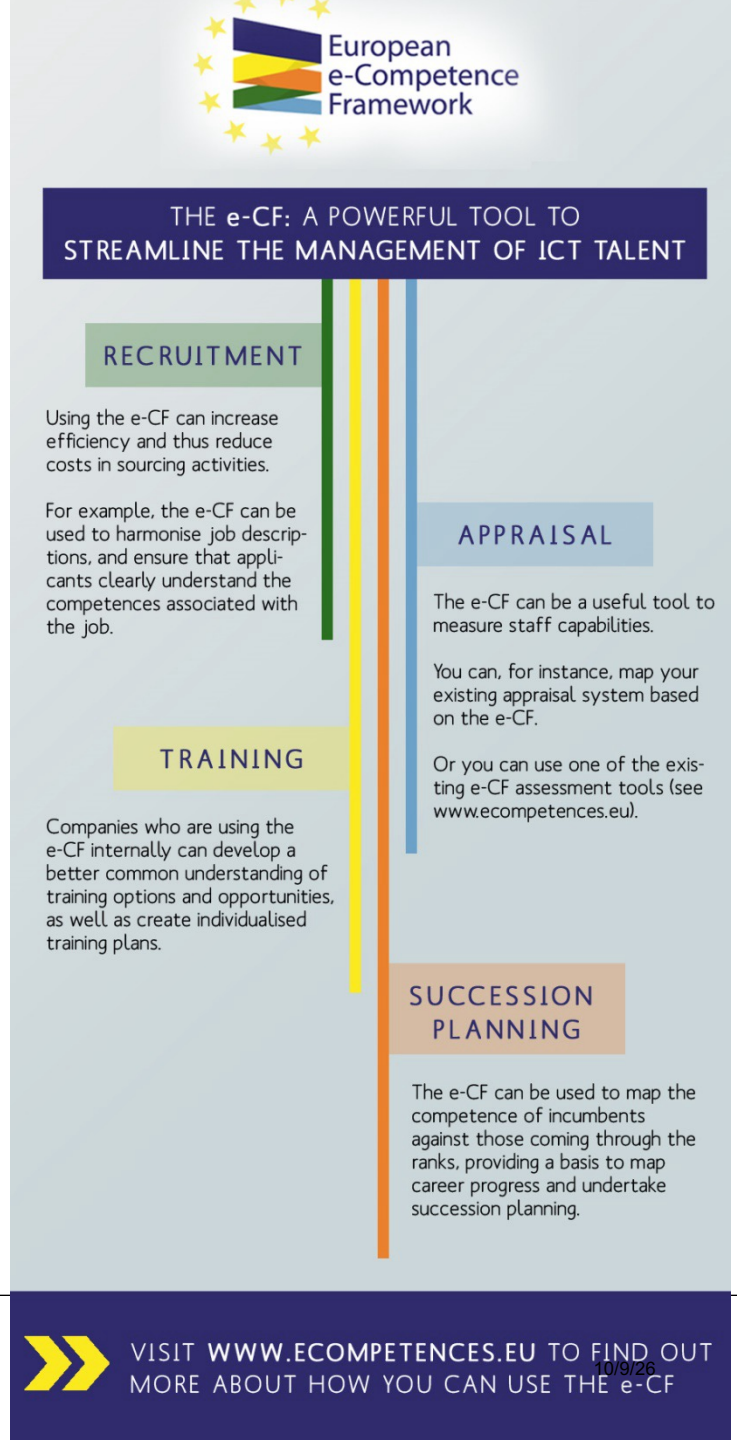
European e-Competence Framework



Source: Bobbert (2020) Copyright “Leading in Digital Security; Twelve Ways to Combat the silent enemy

How educations evolve

- **Cyber Attack Agent,**
- **Cyber Calamity Forecaster,**
- **Machine Risk Officer**
- **Virtual Identity Defender,**
- **Data trash engineer,**
- **Cloud orchestration architect,**
- **Security vaccinator,**
- **Cyber talent magnet,**
- **AI auditor,**
- **Security pusher,**
- **Security User Experience (SUX) Designer**
- **Cyber Philosopher,**
- **Cyberdiplomat,**
- **Chief Information Security Orchestrator**



Source: Bobbert (2020) Copyright “Leading in Digital Security; Twelve Ways to Combat the silent enemy

Source: Bobbert (2020) Copyright
“Leading in Digital Security; Twelve Ways to Combat the silent enemy

New emerging role: Chief Information Security Orchestrator

Orchestrating:

Economics since the CISO needs to rely on detailed reliable source data to determine the cyber risk level in the context of all other risks. And explicating and selling to the board the "biggest bang for the buck", based on facts and figures. This is why we educate in our ISM module “Cybereconomics” and risk quantification techniques.



Talent because of the ongoing "war" on security talent that anchors risk and security leadership, craftsmanship and ownership to continuous "sharpening the saw"[1] and streamline the operation.





Third-party risks in a hybrid distributed environments are the biggest risk for platform-based business models working in a large eco-api-based-system that require clear predefined indicators to monitor the cyber performance over multiple environments (from left to right).

Voting statements

A CISO should be fired after a major breach, even if they warned management beforehand.

The best CISO is not the most technical person in the room.

The board, not the CISO, should carry the main responsibility for cyber risk.

Security awareness training is mostly theatre.

A CISO must sometimes accept known vulnerabilities for business reasons.

In many companies, the CISO has responsibility without real power.

Would you want to become a CISO? Why or why not?

Reflection

Why did I became a CISO

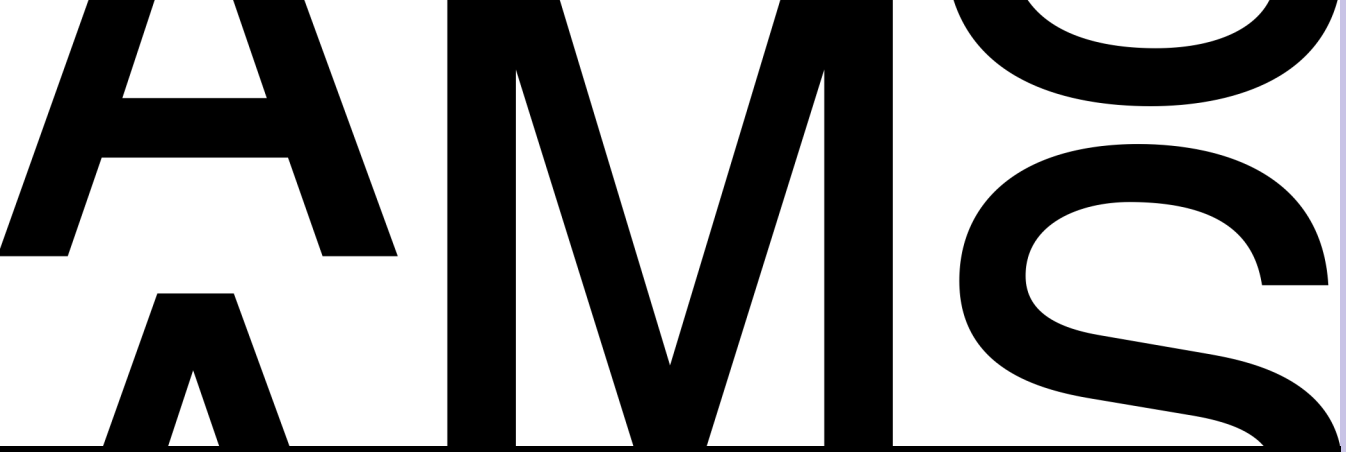
Bringing simplicity into a complex topic

Working with diverse people

Translating risks into (proportional) action

I like a good incident (problem)

Reflection



End

10/9/26

Antwerp Management School

The role of the CISO: Enable Value

- In 2015 Accenture did research into so-called “leapfrog companies” that outperform in the field of Information Security compared to others. For example, due to the positioning of the CISO as a strategic role “These relatively new aspects of the role require CISOs to be successful change agents. To do this they need to be able to reflect on, and understand, the impact of their role on organisational culture”
- IT Policy Compliance Group reports that firms that standardise procedures and controls for IS and manage IS via a dedicated IS staff which is led by a CISO achieve 8.5% higher revenue than industry averages (n= 3000 organisations)
- Hooper et al. states “organisations need to embrace their concern about cybersecurity and build it into their selection criteria for board members”
- In 2007 Harvard professors Hunter and Westerman examined companies that treated risk management as a continuous improvement process and showed that those who did were perceived to have higher market value [90].
- For some companies BIS is perceived as a competitive advantage which helps them distinguish themselves from competitors [96].
- Shackelford says: *“over 90% of respondents reported experiencing a cyber-attack during the last year, costing on average more than $2 million per organisation. Such attacks have been shown to negatively impact the stock prices of targeted firms”*

Source: Bobbert (2018) Improving the Maturity of Business Information Security

Optional CSM Literature: Cyber Resilience

Optional Reading

1. Alhidaifi (2024)
   A Survey on Cyber Resilience: Key Strategies, Research Challenges, and Future Directions.
   Focuses primarily on defining, examining, and strengthening cyber resilience strategies.
   https://doi.org/10.1145/3649218.
   https://openresearch.surrey.ac.uk/esploro/outputs/journalArticle/A-Survey-on-Cyber-Resilience-Key/99928922402346

2. Smith, S. (2023)
   Towards a Scientific Definition of Cyber Resilience. International Conference on Cyber Warfare and Security, 18(1), 379–386.
   Offers a conceptual and theoretical basis for cyber resilience, laying the groundwork for future research and frameworks. https://doi.org/10.34190/iccws.18.1.960

CSM Literature: Cybersecurity Governance & Board Oversight

Optional Reading

1. AlGhamdi (2020)
   Information security governance challenges and critical success factors systematic review.
   Explores governance frameworks, challenges, and success factors in information security.
   https://doi.org/10.1016/j.cose.2020.102030. https://www.sciencedirect.com/science/article/abs/pii/S0167404820303035?via%3Dihub

2. Schinagl, Khapova, & Shahim (2021)
   Tensions that Hinder the Implementation of Digital Security Governance.
   Investigates governance hurdles in implementing digital security practices.
   https://research.vu.nl/ws/portalfiles/portal/152953360/Schinagl2021_Chapter_TensionsThatHinderTheImplementationOfDigitalSecurityGovernance.pdf. Published by Springer Nature Switzerland AG 2021. A. Jøsang et al. (Eds.): SEC 2021, IFIP AICT 625, pp. 430–445, 2021. https://doi.org/10.1007/978-3-030-78120-0_28

3. Nominet (2020)
   The CISO Stress Report.
   Presents survey findings on the stressors faced by CISOs, highlighting governance and leadership implications.
   https://media.nominetcyber.com/wp-content/uploads/2020/02/Nominet_The-CISO-Stress-Report_2020_V10.pdf

4. Dutton, J. E., Ashford, S. J., O'Neill, R. M., & Lawrence, K. A. (2001)
   Moves that matter: Issue selling and organizational change.
   Although not cybersecurity-specific, it addresses how issues (like security) are escalated within leadership structures. Moves that matter: Issue selling and organizational change. *Academy of Management journal, 44*(4), 716-736.

CSM Literature: Cybersecurity Governance & Board Oversight

Optional Reading

5. Higgs, J. L., Pinsker, R. E., Smith, T. J., & Young, G. R. (2016).
The relationship between board-level technology committees and reported security breaches.
Empirical study on how board committee structures can influence security breach outcomes.The relationship between board-level technology committees and reported security breaches. *Journal of Information Systems*, *30*(3), 79–98. https://doi.org/10.2308/ISYS-51402

6. Huber, C., May, M., & White, O. (2021).
A spotlight on boards' response to the new risk environment. How boards are changing the way they think about risk in strategic decision-making.
Examines how boards adapt risk oversight and strategic decision-making to new threats, including cyber risks.
Journal of Risk Management in Financial Institutions, *14*(2), 115–120.
https://www.ingentaconnect.com/content/hsp/jrmfi/2021/00000014/00000002/art00002

7. Rothrock, Kaplan, & van der Oord (2018)
The board's role in managing cybersecurity risks.
Discusses best practices for boards in overseeing cyber risk and safeguarding organizational assets. *MIT Sloan Management Review*, *59*(2), 12–15. https://sloanreview.mit.edu/article/the-boards-role-in-managing-cybersecurity-risks/